

Cybersecurity Daily Newsletter

Vol. 001 | 2026-05-22 07:00 WIB

Top 5 Highlights

- Wahlap data leak exposes 18.9 million records from WeChat mini-program ecosystem
- Deleted Google API keys remain active for up to 23 minutes, study finds
- New Linux malware 'Showboat' targets Middle East telecom provider
- 'First VPN' service used by cybercriminals dismantled in international operation
- Nvidia releases driver updates to fix 14 critical vulnerabilities

Threat Intelligence (10)

01. Deleted Google API keys remain active for up to 23 minutes, study finds

While the Google Cloud Platform console indicates immediate deletion, researchers found that keys take an average of 16 minutes to become fully inactive, with the longest observed delay reaching 23 minutes.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/deleted-google-api-keys-remain-active-for-up-to-23-minutes-study-finds>

02. New Linux malware 'Showboat' targets Middle East telecom provider

Showboat is believed to be utilized by Chinese-affiliated threat actors, with command-and-control infrastructure linked to Chengdu, China.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/new-linux-malware-showboat-targets-middle-east-telecom-provider>

03. Dems slam Trump for making cybersecurity hold out the tin cup while splurging on ballroom and Jan. 6 'slush fund'

'Budgets are moral documents,' Rep. Delia Ramirez said

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/05/22/dems-slam-trump-cyber-cuts-amid-ballroom-jan-6-slush-fund/5244618>

04. Alleged Kimwolf Botmaster 'Dort' Arrested, Charged in U.S. and Canada

Canadian authorities on Wednesday arrested a 23-year-old Ottawa man on suspicion of building and operating Kimwolf, a fast spreading Internet-of-Things botnet that enslaved millions of devices for use in a series of massive distributed denial-of-service (DDoS) attacks over the past six months. KrebsOnSecurity publicly named the suspect in February 2026 after...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://krebsonsecurity.com/2026/05/alleged-kimwolf-botmaster-dort-arrested-charged-in-u-s-and-canada/>

05. How CISOs Should Prep for Agentic-Ready AI BOMs

Finding ways to document both component and execution attributes for AI bill of materials (AI BOM).

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cyber-risk/how-cisos-should-prep-for-agentic-ready-ai-boms>

06. FCC, Github, MiniShai-hulud, Stated of Supply Chain, Itron, CRA, NIS2, and more!! - PSW #927

FCC, Github, MiniShai-hulud, Stated of Supply Chain, Itron, CRA, NIS2, and more!! - PSW #927

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.scworld.com/podcast-segment/14954-fcc-github-minishai-hulud-stated-of-supply-chain-itron-cra-nis2-and-more-psw-927>

07. Threat hunters find Google API keys still usable 23 minutes after deletion

Plenty of time for bad actors to grab data or hit you with a giant bill

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/devops/2026/05/21/threat-hunters-find-google-api-keys-still-usable-23-minutes-after-deletion/5244504>

08. Google API Keys Remain Active After Deletion

A security researcher discovered the API keys can still be used for 23 minutes after deletion, even though the cloud provider claims deletion is immediate.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/identity-access-management-security/google-api-keys-active-after-deletion>

09. AWS KY3P report now available for third-party supplier due diligence

We're excited to announce that Amazon Web Services (AWS) has completed the S&P; Global Know Your Third Party (KY3P) assessment of its security posture. This assessment demonstrates our continued commitment to meet the heightened expectations of cloud service providers. Customers can now use the AWS KY3P assessment to reduce their supplier due diligence burde...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://aws.amazon.com/blogs/security/aws-ky3p-report-now-available-for-third-party-supplier-due-diligence/>

10. HackerOne takes an axe to its bug bounty rewards

Critical flaw payouts slashed by more than 75%

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/05/21/hackerone-takes-an-axe-to-its-bug-bounty-rewards/5244458>

Latest Vulnerabilities (10)

01. 'First VPN' service used by cybercriminals dismantled in international operation

First VPN marketed itself on Russian-speaking cybercrime forums as a reliable tool for anonymity, offering features like anonymous payments and concealed infrastructure to help users evade law enforcement.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/first-vpn-service-used-by-cybercriminals-dismantled-in-international-operation>

02. Nvidia releases driver updates to fix 14 critical vulnerabilities

The vulnerabilities affect GeForce, RTX, Quadro, Tesla, and NVS product lines, as well as vGPU and Cloud Gaming software.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/nvidia-releases-driver-updates-to-fix-14-critical-vulnerabilities>

03. Critical vulnerability in Cisco Secure Workload rated at maximum severity

A critical vulnerability in the on-premises version of the Cisco Secure Workload security platform could allow a threat actor to obtain the privileges of a site admin, enabling them to compromise endpoints and read or modify configuration data. "CSOs need to drop what they are doing and patch this immediately," warned consultant Robert Enderle, who heads t...

Why it matters: Publicly discussed 0-days often see rapid weaponization, increasing the risk of opportunistic attacks at scale.

Recommendation: Apply vendor guidance immediately, reduce attack surface, and monitor for IoCs/exploitation telemetry until patches are fully deployed.

Sources: <https://www.csoonline.com/article/4175913/critical-vulnerability-in-cisco-secure-workload-rated-at-maximum-severity.html>

04. Microsoft patches two zero-day flaws in Defender

Microsoft released emergency fixes for two zero-day vulnerabilities in the malware protection components of Microsoft Defender. The flaws allow local attackers to gain system-level privileges or cause the anti-malware service to stop working correctly. Both conditions are valuable in a malware attack, first to prevent detection if the system relies only on...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4175970/microsoft-patches-two-zero-day-flaws-in-defender.html>

05. Unpatched ChromaDB flaw leaves servers open to remote code execution

Researchers have published details about a critical vulnerability in ChromaDB that could allow unauthenticated attackers to execute arbitrary code and access sensitive data on machines running the open-source vector database. The issue, tracked as CVE-2026-45829, is located in ChromaDB's API server and was published by researchers at HiddenLayer after repor...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4175958/unpatched-chromadb-flaw-leaves-servers-open-to-remote-code-execution.html>

06. CVE-2026-47114 | IINA up to 1.4.2 URL argument injection (EUVD-2026-31331)

A vulnerability classified as critical was found in IINA up to 1.4.2. Affected is an unknown function of the component URL Handler. Such manipulation leads to argument injection. This vulnerability is listed as CVE-2026-47114. The attack may be performed from

remote. There is no available exploit. Upgrading the affected component is advised.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/365079>

07. CVE-2026-8417 | Concrete CMS up to 9.5.0 do_update cross-site request forgery (EUVD-2026-31334)

A vulnerability classified as problematic has been found in Concrete CMS up to 9.5.0 . This impacts the function do_update of the file /dashboard/extend/update/do_update/ . This manipulation causes cross-site request forgery. This vulnerability is tracked as CVE-2026-8417 . The attack is possible to be carried out remotely. No exploit exists.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/365078>

08. CVE-2026-4843 | mrdollar4444 GSheet for Woo Importer Plugin up to 2.3.1 on WordPress Configuration process_ajax_restore_action authorization (efa-9427-380 / EUVD-2026-31333)

A vulnerability described as critical has been identified in mrdollar4444 GSheet for Woo Importer Plugin up to 2.3.1 on WordPress. This affects the function process_ajax_restore_action of the component Configuration Handler . The manipulation results in missing authorization. This vulnerability is identified as CVE-2026-4843...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/365077>

09. CVE-2026-8135 | Concrete CMS up to 9.5.0 REST API json_decode deserialization (EUVD-2026-31336)

A vulnerability marked as problematic has been reported in Concrete CMS up to 9.5.0 . The impacted element is the function json_decode of the component REST API . The manipulation leads to deserialization. This vulnerability is referenced as CVE-2026-8135 . Remote exploitation of the attack is possible. No exploit is available.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/365076>

10. CVE-2026-8134 | Concrete CMS up to 9.5.0 File Upload ptComposerFormLayoutSetControlCustomTemplate filename control (EUVD-2026-31335)

A vulnerability labeled as problematic has been found in Concrete CMS up to 9.5.0 . The affected element is an unknown function of the component File Upload Handler...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuln.db.com/vuln/365075>

Data Breach & Cybercrime (10)

01. Wahlap data leak exposes 18.9 million records from WeChat mini-program ecosystem

Security researchers discovered an open Elasticsearch instance belonging to Wahlap, a prominent arcade game manufacturer that collaborates with industry giants like Sega.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/wahlap-data-leak-exposes-18-9-million-records-from-wechat-mini-program-ecosystem>

02. Senator urges classified briefing after CISA data leak on GitHub

A GitHub leak exposed CISA credentials, sparking concerns over secrets management and leadership.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/news/senator-urges-classified-briefing-after-cisa-data-leak-on-github>

03. Cybercriminal VPN Dismantled in Europol Crackdown

First VPN, a service used by ransomware actors and fraudsters, was dismantled by Europol

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/first-vpn-takedown-europol/>

04. Apple blocked over \$11 billion in App Store fraud in 6 years

Apple revealed that it blocked over \$11 billion in fraudulent App Store transactions over the last six years, more than \$2.2 billion in potentially fraudulent App Store transactions in 2025 alone. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/apple/apple-blocked-22-billion-in-fraudulent-app-store-transactions-in-2025/>

05. GitHub Breach Traced to Malicious 'Nx Console' VS Code Extension

A threat actor compromised an Nx developer and posed as a legitimate maintainer to publish a malicious extension on Visual Studio Marketplace

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/github-breach-nx-console-vs-code/>

06. GitHub, Grafana Labs breaches traced back to TanStack supply chain compromise

GitHub CISO Alexis Wales has named the malicious VS Code extension behind the breach they suffered at the hands of the threat group TeamPCP: Nx Console, a popular developer tool with 2.2 million installs. A malicious version of the otherwise benign extension was used to steal secrets and developer credentials, which were then used to move through CI/CD pipe...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/05/21/github-grafana-breach-root-cause-nx-console/>

07. Attackers spill plaintext passwords of 46k Myspace93 users after 2021 breach

Leakage blamed on treacherous friends exposed unencrypted credentials, email addresses

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/05/21/46k-plaintext-passwords-pwned-in-myspace93-breach/5244024>

08. Nine-Year-Old Linux Kernel Flaw Leaks SSH Keys and Password Hashes

Qualys finds nine-year-old Linux ptrace flaw exposing SSH keys and password hashes locally

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/linux-kernel-ptrace-flaw-ssh-keys/>

09. ThreatsDay Bulletin: Linux Rootkits, Router 0-Day, AI Intrusions, Scam Kits and 25 New Stories

This week starts small. A token leaks. A bad package slips in. A login trick works. An old tool shows up again. At first, it feels like the usual mess. Then you see the pattern: attackers are not always breaking in. They are using the parts we already trust. That is what makes it worrying. The danger is in normal things now - updates, apps, cloud buttons, s...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/05/threatsday-bulletin-linux-rootkits.html>

10. Apple Rejected 2 Million App Store Submissions in 2025 for Security and Fraud Prevention

The company blocked over 1.1 billion accounts and \$2.2 billion in potentially fraudulent transactions. The post Apple Rejected 2 Million App Store Submissions in 2025 for Security and Fraud Prevention appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/apple-rejected-2-million-app-store-submissions-in-2025-for-security-and-fraud-prevention/>